

Event Information:

EventID :
304
Event Time :
Sep, 17, 2024, 12:05 PM
Rule :
SOC326 - Impersonating Domain MX Record Change Detected
Level :
Security Analyst
Source Address :
no-reply@cti-report.io
Destination Address :
soc@letsdefend.io
Subject :
Impersonating Domain MX Record Change Detected
Trigger Reason :
The MX record of a suspicious domain was changed, suggesting potential phishing activity.
Domain :
letsdefwnd[.]io
Mx_record :
mail.mailerhost[.]net
Device Action :
Allowed

Analysis Steps:

Email logs were searched for the specific email mentioned in the alert.

From:

no-reply@cti-report.io

To:

soc@letsdefend.io

Subject:

Impersonating Domain MX Record Change Detected

Date:

Sep, 17, 2024, 12:05 PM

Action:

Allowed

We have identified incidents amongst your assets, please check them carefully.

Incident ID

304

Title

Impersonating Domain MX Record Change Detected

Incident Product

Digital Risk Protection

Incident Main Type

Brand Protection

Incident Sub Type

Impersonating Domain

Assets

LETSDDEFEND

Risk Level

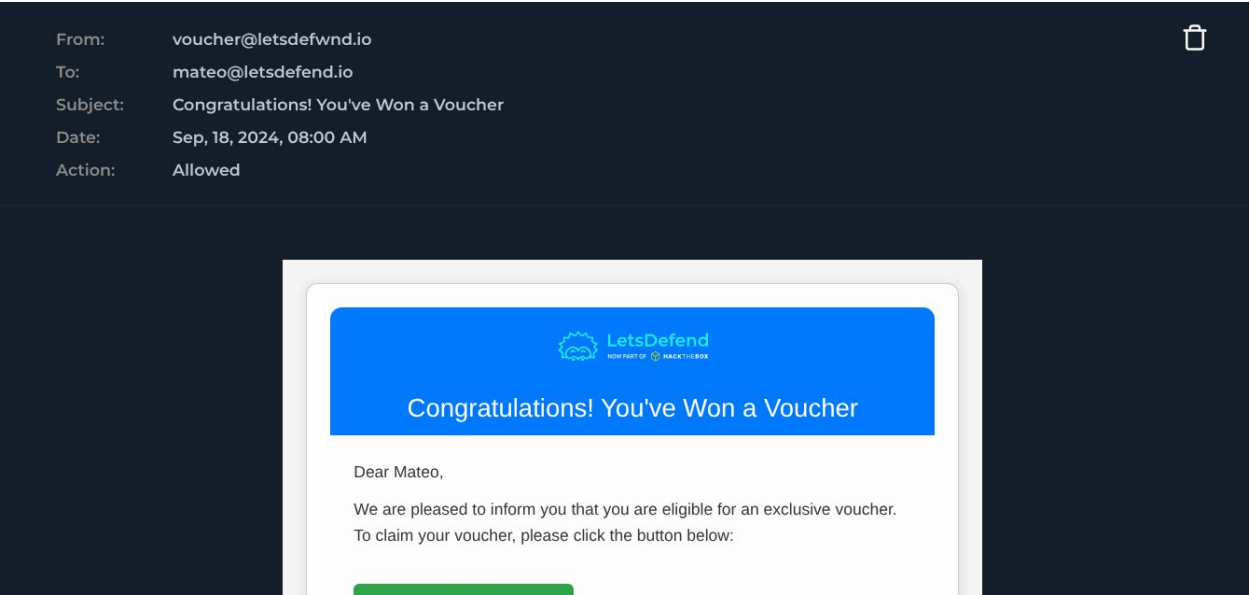
HIGH

This is a threat intelligence email highlighting a change in MX Record impersonating LetsDefend.

Threat actors have registered the domain `letsdefwnd[.]io`, which is a deliberate typosquat of the legitimate `letsdefend.io` domain.

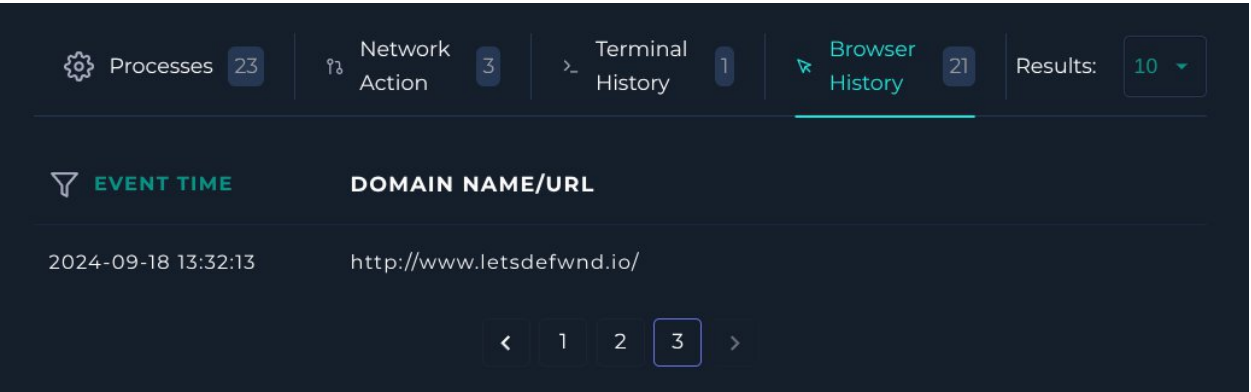
An MX (Mail Exchange) record tells the internet which mail servers handle emails for a specific domain. The Threat: By configuring the MX record to `mail.mailerhost[.]net`, the attackers have fully set up the necessary infrastructure to send forged phishing emails that appear to come from the LetsDefend brand.

Following this we can see a phishing email has been received from the impostor domain.



The link leads to the [http://letsdefwnd\[.\]io/](http://letsdefwnd[.]io/) website. But OSINT reveals very little information for this site.

Checking endpoint logs we can see that the user accessed the malicious domain.



We can see what IP the domain resolved to at the time of the incident.

Processes 23	Network Action 3	Terminal History 1	Browser History 21	Results: 10
EVENT TIME	DESTINATION DOMAIN/IP ADDRESS			
Sep 18 2024 01:32:09	23.44.17.219			
Sep 18 2024 01:32:13	45.33.23.183			
Sep 18 2024 01:32:39	169.254.169.254			

This IP address seen after the malicious site was accessed is a massive target for threat actors. If an attacker manages to compromise a cloud-hosted machine, one of the very first things they will do is try to reach 169[.]254.169.254.

They do this because the Metadata Service frequently stores active, temporary security credentials (such as AWS IAM keys).

If the attacker downloads those keys, they can use them to completely bypass the machine and start attacking the organisation's broader cloud infrastructure directly.

As such we can piece together:

01:32:13: Mateo's machine connects to 45[.]33.23.183 (the malicious IP associated with the typosquatted phishing domain). This proves he clicked the link.

01:32:39: Tthe machine reaches out to 169[.]254.169.254.

Although not 100% evidence-able this sequence strongly suggests that a phishing payload was successful, and the attacker immediately attempted to steal Mateo's cloud access keys. Therefore, it is prudent to treat this as a successful True Positive.

The offending IP is not in our CTI database and is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. VirusTotal indicates it is a US address associated with 45[.]33.23.183 AS 63949 (Akamai Connected Cloud) 2/91 security vendors flagged this IP address as malicious.

2

/ 91

Community Score

7

2/91 security vendors flagged this IP address as malicious

45.33.23.183 (45.33.0.0/17)

AS 63949 (Akamai Connected Cloud)

US

Last Analysis Date

6 days ago

DETECTION

DETAILS

RELATIONS

COMMUNITY (85)

Join our Community

and enjoy additional community insights and crowdsourced detections, plus an API key to [automate checks](#).

Security vendors' analysis

Do you want to automate checks?

Chong Lua Dao	Malicious	Forcepoint ThreatSeeker	Malicious
alphaMountain.ai	Suspicious	Gridinsoft	Suspicious
AbuseIP	Clean	Acronis	Clean
ADMINUS Labs	Clean	AILabs (MONITORAPP)	Clean

On AbuseIPDB the address has been reported 85 times with a 0% confidence.

45.33.23.183 was found in our database!

This IP was reported **85** times. Confidence of Abuse is **0%**:

?

0%

ISP	Linode
Usage Type	Data Center/Web Hosting/Transit
ASN	AS63949
Hostname(s)	45-33-23-183.ip.linodeusercontent.com
Domain Name	linode.com
Country	 United States of America
City	Richardson, Texas

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a True Positive phishing campaign utilising a typosquatted domain (letsdefwnd[.]io) that resulted in a successful endpoint compromise and attempted cloud credential theft. Following an initial CTI early-warning alert regarding the domain's MX record configuration, a malicious email breached the perimeter. Endpoint telemetry confirms the user clicked the malicious link, immediately followed by the host attempting to access the cloud Instance Metadata Service (IMDS), indicating a high-severity breach.

Incident Details

- **Alert Name:** SOC326 - Impersonating Domain MX Record Change Detected
- **Impersonating Domain:** letsdefwnd[.]io
- **Malicious IP:** 45[.]33.23.183
- **Target Account:** mateo[@]letsdefend[.]io

Analysis and Evidence

- **Infrastructure Staging:** A threat intelligence email received on Sep, 17, 2024, at 12:05 PM indicated that threat actors registered letsdefwnd[.]io and configured its MX records to mail.mailerhost[.]net.
- **Phishing Execution:** On Sep, 18, 2024, at 08:00 AM, an email was successfully delivered from voucher[@]letsdefwnd[.]io to the internal user mateo[@]letsdefend[.]io. The email utilised the subject line "Congratulations! You've Won a Voucher" and included an embedded link directing the victim to hxxp://letsdefwnd[.]io/. The email gateway action was recorded as "Allowed".
- **Payload & Lateral Movement:** Network logs confirm the user clicked the link, with the machine successfully establishing a connection to the malicious domain's IP (45[.]33.23.183) at 01:32:13 PM. At 01:32:39 PM, the compromised machine reached out to 169[.]254.169.254. This sequence strongly suggests the phishing payload successfully executed and the attacker immediately attempted to query the cloud metadata service to steal active, temporary AWS IAM access keys.

Threat Intelligence

- **Brand Impersonation:** The domain letsdefwnd[.]io is a deliberate typosquat designed to closely mimic the legitimate letsdefend[.]io brand. By setting up the MX records, the attackers successfully forged the infrastructure needed to bypass basic email filters and conduct targeted social engineering.
- **OSINT (Infrastructure):** VirusTotal indicates 45[.]33.23.183 is a US address associated with Akamai Connected Cloud (AS 63949), with 2/91 security vendors flagging the IP address as malicious. AbuseIPDB reports this IP 85 times with a 0% confidence of abuse.

Actions Taken

1. Analysed the initial CTI alert to identify the staging of the impersonating domain and its associated mail server.
2. Searched internal email logs and identified a successful phishing email delivery to mateo[.]letsdefend[.]io originating from the fraudulent domain.
3. Correlated endpoint network telemetry, confirming the user accessed the malicious IP and subsequently attempted an unauthorised connection to the local cloud metadata IP (169[.]254.169.254).
4. Purged the malicious email from the user's inbox to prevent any further interaction with the payload.
5. Isolated the endpoint.
6. Declared the alert a True Positive and escalated.

Let's Defend Result

SOC326 - Impersonating Domain MX Record Change Detected
True Positive (+5 Point)
Check If Someone Opened the Malicious File/URL? (+5 Point)
Check If Mail Delivered to User? (+5 Point)
Analyze Url/Attachment (+5 Point)
Are there attachments or URLs in the email? (+5 Point)